



Sunnyvale

A computer sciences company

CloudConf 2026 ☁



Friends Don't Let Friends Hardcode **Undisclose** Passwords

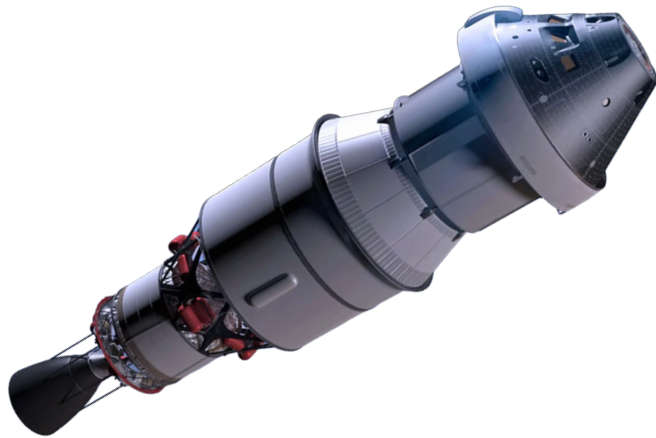
Date: May 6th, 2026

Location: Turin, Italy

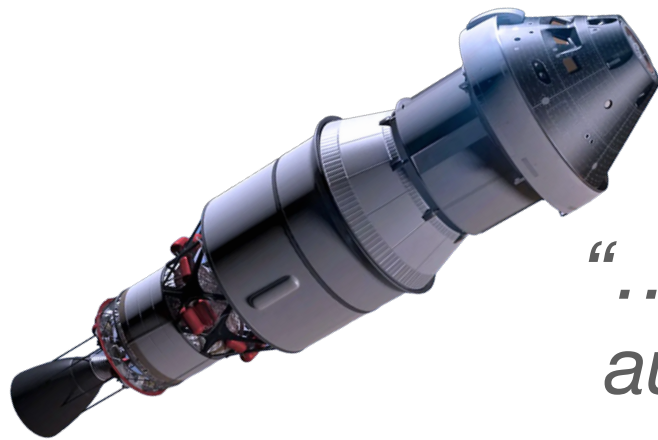
Event Type: Lightning Talk

Gartner 2026 tech trends

- AI-Native Development Platforms
- AI Supercomputing Platforms
- Confidential Computing
- Multiagent Systems
- Domain-Specific Language Models
- Physical AI
- Preemptive Cybersecurity
- Digital Provenance
- AI Security Platforms
- Geopatriation



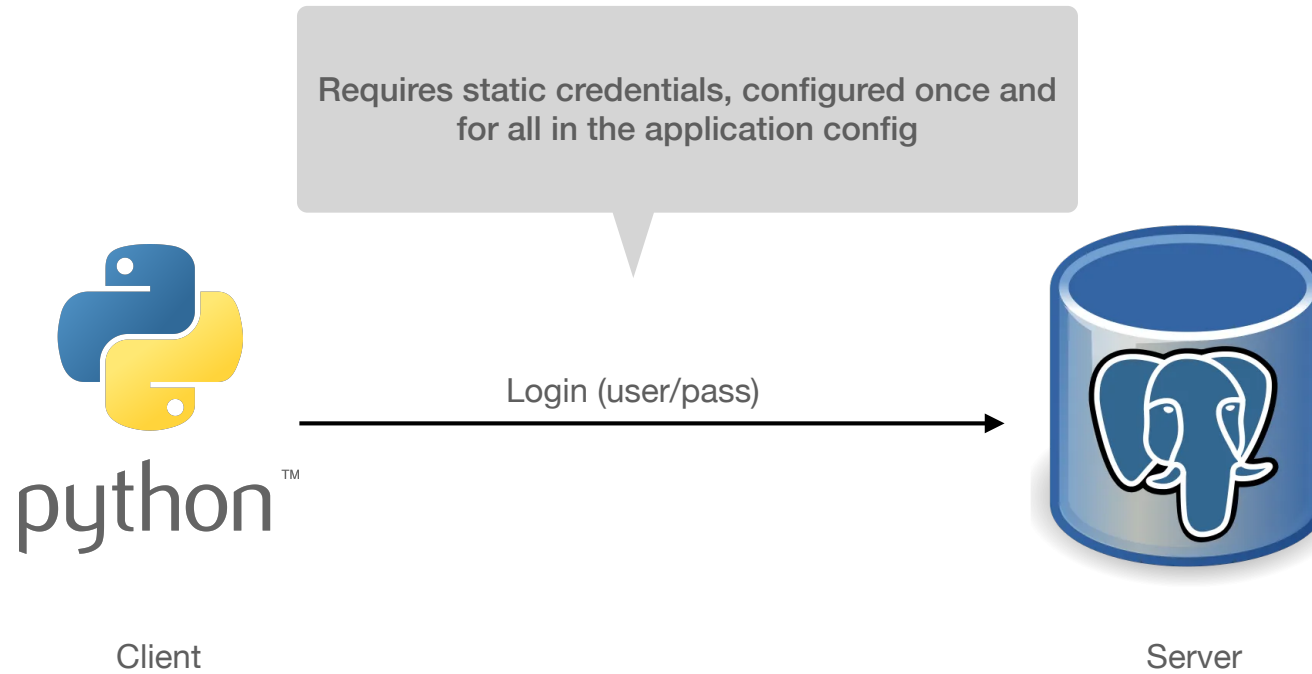
Everything is good but...



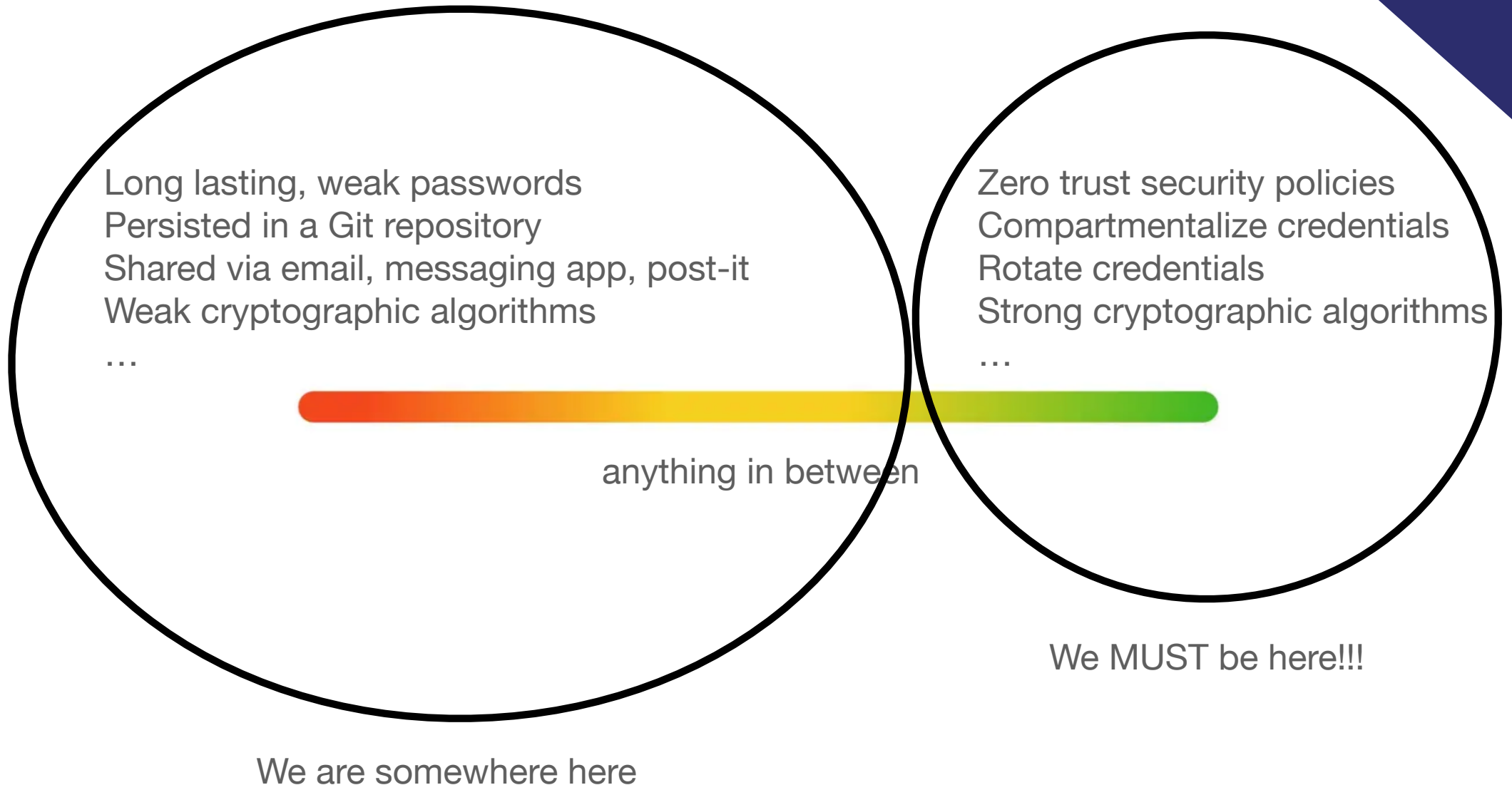
*“...how do your applications
authenticate to their DBs?”*



The standard way



Addressing security debt



A success story...

...starts with an issue to address, this was our goal.

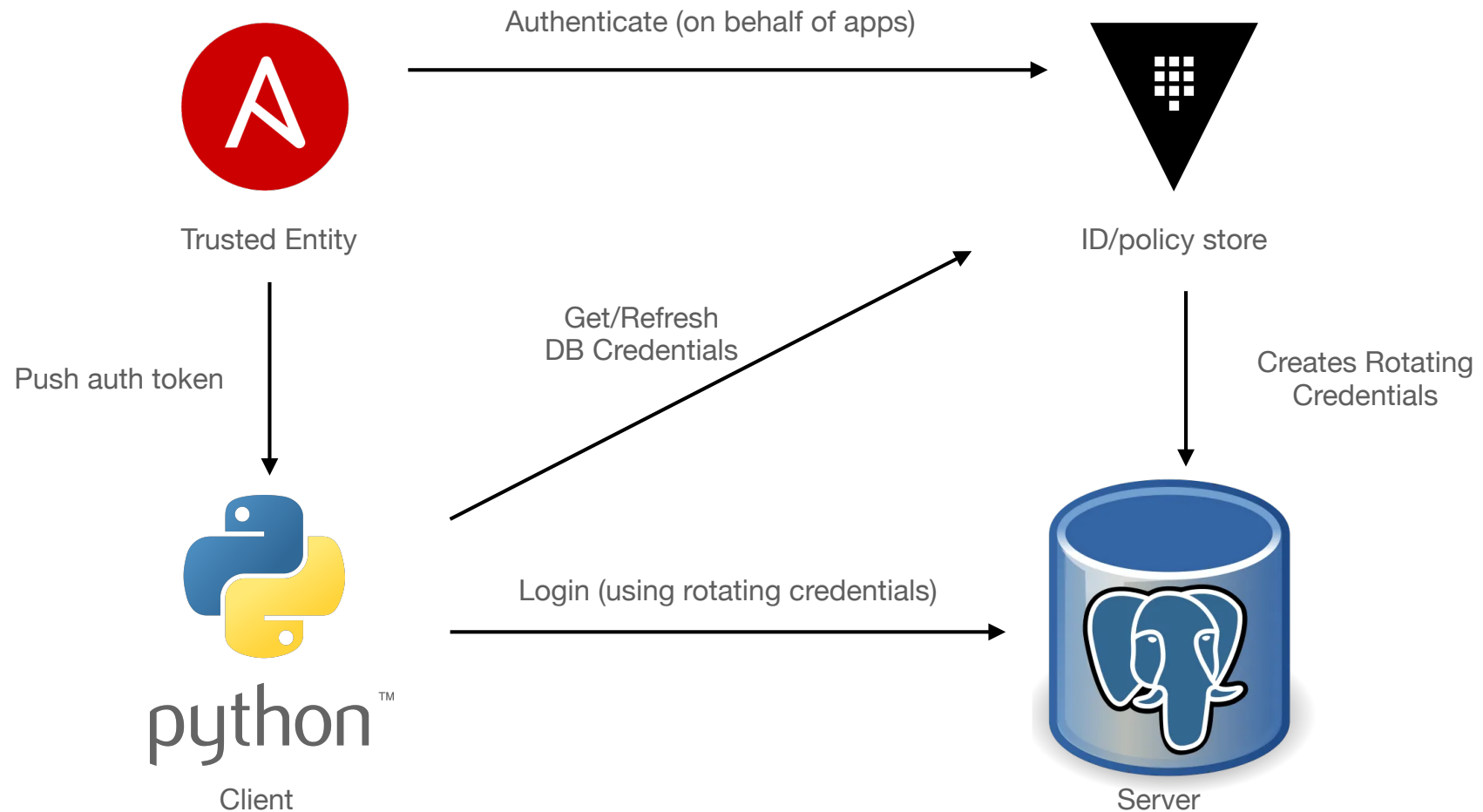
“To provide an app to database authentication mechanism, which had to be:

- *Compartmentalized authentication/s (defense in depth)*
- *Short-lived credentials (rotating)*
- *Fine-grained authorization by design (a.k.a. least-privilege roles)*
- *Centralized authentication logic*
- *Auditable and observable*

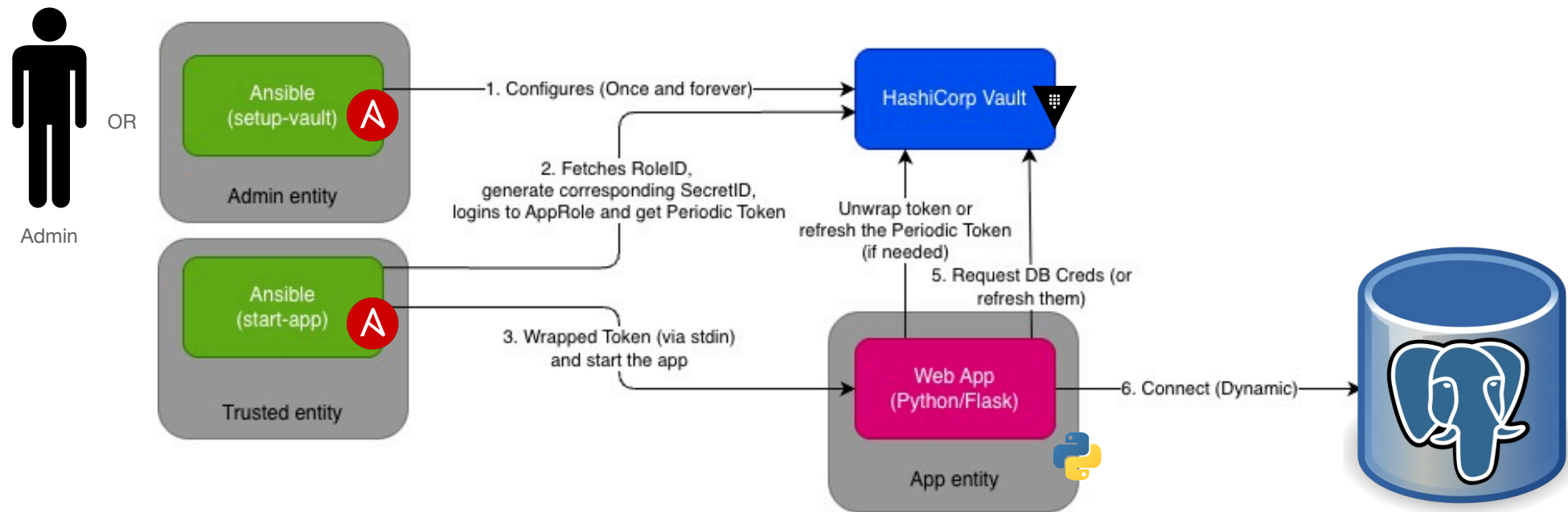
”

The answer has been: **Brokered Authentication Pattern (BAP)**

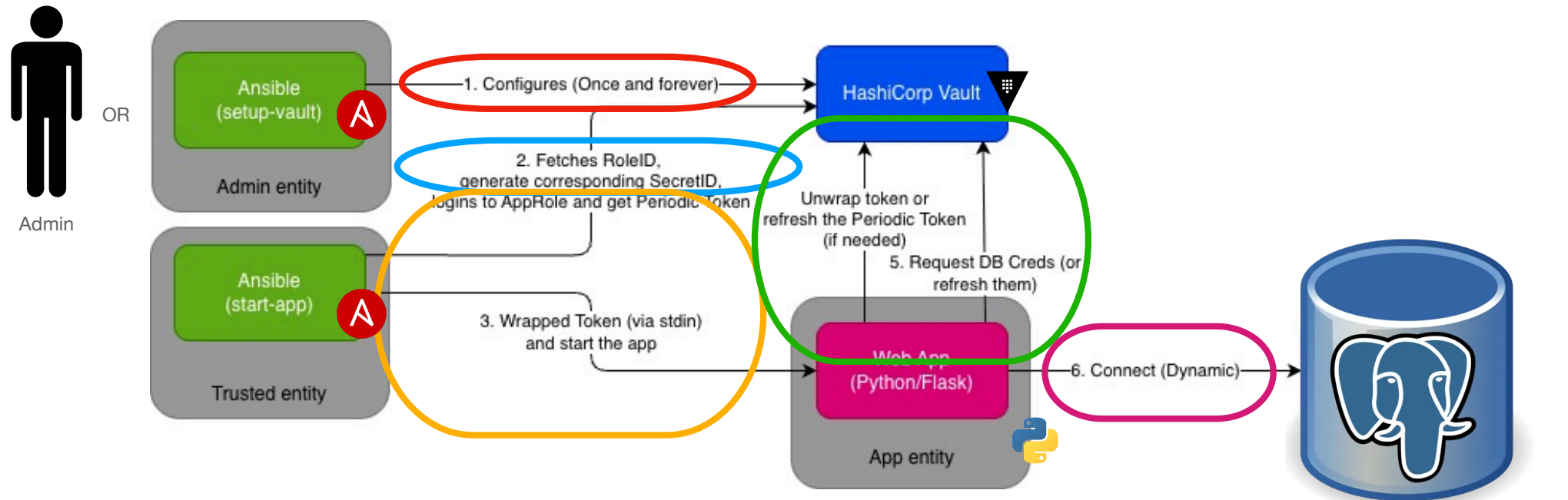
The Brokered Authentication way



BAP Proof of Concept



BAP authentication compartments



- Admin token
- CI/CD token
- AppRole auth (on behalf of App)
- Periodic Token (initially wrapped)
- Rotating PostgreSQL creds

Credentials TTLs (can be improved)

In a real-world production environment, the static CICD token is completely replaced by Identity Federation via OIDC / JWT

Credential / Token	Issuer / Creator	Consumer	TTL / Lifetime	Purpose
<u>Root Token</u>	Vault (Startup)	Ansible (Setup)	Infinite	Initial setup of Vault AppRole auth, policies, and DB secret engines.
<u>CICD Token</u>	Ansible (Setup) via Root	Ansible (Start)	System Default (32 days)	Securely fetch <code>RoleID</code> and generate a <code>SecretID</code> under a restricted policy for app init.
<u>RoleID</u>	Vault AppRole	Ansible (Start)	Infinite	Static identifier acting as the username for the application.
<u>SecretID</u>	Vault AppRole (via Ansible CICD Token)	Ansible (Start)	5m (Single-use)	High-privilege dynamic password acting as the second factor for AppRole login.
<u>Wrapping Token</u>	Vault (AppRole Login)	Application	60s (Single-use)	Securely deliver the actual payload Vault Token to the application through <code>stdin</code> .
<u>App VAULT_TOKEN</u>	Vault (Unwrapped by Application)	Application	1h (Periodic, Renewable indefinitely)	Authorize the application to fetch dynamic database credentials.
<u>Database Credentials</u>	Vault DB Engine	Application	Default 1h (Max 24h)	Authenticate PostgreSQL connections dynamically.

There's no pattern without drawbacks

- Highly dependent on HashiCorp Vault functionalities (OpenBao as a possible alternative)
- Complex infrastructure, especially multi-process/worker applications
- Application can not "Self-Heal" or be restarted without CI/CD (it wouldn't have the required credentials)
- CI/CD infrastructure becomes a high-value target for attackers
- The app is entirely responsible for keeping its VAULT_TOKEN alive (it might be a fragile mechanism)
- ... can you spot others?

Source code

The screenshot shows the GitHub repository page for 'vault-approle' by 'sunnyvale-academy'. The repository is private and has 1 branch and 0 tags. The main branch is 'main'. The repository contains several files and folders, including 'ansible', 'app', '.gitignore', 'README.md', 'architecture.drawio', and 'docker-compose.yml'. The 'README.md' file is selected, showing the 'Architecture' section. The architecture section describes the three main phases of the demo: Vault Configuration, Credential Delivery by Ansible, and the Application Runtime flow. A sequence diagram illustrates these phases, showing the interaction between 'Ansible (Trusted Entity)', 'HashiCorp Vault', 'Web App (Python/Flask)', and 'PostgreSQL'. The diagram shows 'Phase 1: Configuration (Root Token)' and 'Phase 2: Secure Token Delivery (CICD Token)'. The right sidebar shows the 'About' section, 'Releases', 'Packages', 'Contributors', and 'Languages'.

Repository: vault-approle (Private)

Files:

- ansible**: fix: use dynamic vault token instead of fixed string for cid (29 minutes ago)
- app**: Initial commit of vault-approle lab (1 hour ago)
- .gitignore**: chore: ignore local vault token artifact (29 minutes ago)
- README.md**: docs: update sequence diagram and security notes for cic... (18 minutes ago)
- architecture.drawio**: Initial commit of vault-approle lab (1 hour ago)
- docker-compose.yml**: Initial commit of vault-approle lab (1 hour ago)

README

Architecture

Below is a sequence diagram illustrating the three main phases of the demo: Vault Configuration, Credential Delivery by Ansible, and the Application Runtime flow.

Contributors: 1 contributor (denismaggior8)

Languages: Python 100.0%

<https://github.com/sunnyvale-academy/vault-approle>

Grazie!

More at linktr.ee/denismaggior8

